

TP 4.1 : MISE EN PLACE D'UN PARE-FEU pfSense ET SEGMENTATION DU LABORATOIRE

1. Objectifs du TP

L'objectif principal de ce travail pratique est de transformer une architecture réseau initialement ouverte en une infrastructure sécurisée et segmentée. En introduisant pfSense comme pare-feu central, nous visons à :

- Contrôler les flux réseau entre les différentes zones (LAN et WAN).
- Limiter la surface d'attaque du laboratoire.

Passer d'une posture offensive à une posture de défense active (administrateur sécurité/analyste SOC).

2. Architecture du Laboratoire

L'environnement est segmenté en deux interfaces distinctes gérées par pfSense :

- **Zone WAN (Externe) :** Interface configurée en mode NAT (ou accès direct à l'attaquant simulé), permettant l'accès Internet et simulant le réseau non de confiance.
- **Zone LAN (Interne) :** Interface configurée en "Host-Only", regroupant les machines de travail (Ubuntu et Windows).

Configuration IP : pfSense agit comme passerelle par défaut pour les machines du LAN.

3. Configurations et captures d'écran

➤ Configuration réseaux des VMs

Les machines Ubuntu et Windows ont été configurées pour utiliser pfSense comme passerelle

```
morel@morel-virtual-machine:~$ sudo ip addr add 192.168.1.10/24 dev eth0
[sudo] Mot de passe de morel :
Cannot find device "eth0"
morel@morel-virtual-machine:~$ ip link
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN mode DEFAULT group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
4: ens33: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP mode DEFAULT group default qlen 1000
    link/ether 00:0c:29:4c:4e:db brd ff:ff:ff:ff:ff:ff
    altname enp2s1
morel@morel-virtual-machine:~$ sudo ip addr add 192.168.1.10/24 dev ens33
RTNETLINK answers: File exists
morel@morel-virtual-machine:~$ sudo ip route add default via 192.168.1.1
morel@morel-virtual-machine:~$ ping 192.168.1.1
PING 192.168.1.1 (192.168.1.1) 56(84) bytes of data:
64 bytes from 192.168.1.1: icmp_seq=1 ttl=64 time=2.05 ms
64 bytes from 192.168.1.1: icmp_seq=2 ttl=64 time=1.27 ms
64 bytes from 192.168.1.1: icmp_seq=3 ttl=64 time=1.94 ms
64 bytes from 192.168.1.1: icmp_seq=4 ttl=64 time=1.74 ms
64 bytes from 192.168.1.1: icmp_seq=5 ttl=64 time=1.88 ms
^C
--- 192.168.1.1 ping statistics ---
5 packets transmitted, 5 received, 0% packet loss, time 4009ms
rtt min/avg/max/ndev = 1.267/1.776/2.054/0.273 ms
morel@morel-virtual-machine:~$
```

➤ Interface pfSense

L'administration se fait via l'interface web (HTTPS://192.168.1.1) avec les identifiants par défaut (admin /pfSense).

pfSense COMMUNITY EDITION System Interfaces Firewall Services VPN Status Diagnostics Help

WARNING: The 'admin' account password is set to the default value. [Change the password in the User Manager.](#)

Status / Dashboard

System Information

Name pfSense.home.arpa

User admin@192.168.1.10 (Local Database)

System VMware Virtual Machine
Netgate Device ID: fda06334068eec1ab66f

BIOS Vendor: **Phoenix Technologies LTD**
Version: **6.00**
Release Date: **Thu Nov 12 2020**

Version **2.6.0-RELEASE** (amd64)
built on Mon Jan 31 19:57:53 UTC 2022
FreeBSD 12.3-STABLE
Unable to check for updates

CPU Type AMD Ryzen 5 PRO 3500U w/ Radeon Vega Mobile Gfx
2 CPUs: 1 package(s) x 2 core(s)
AES-NI CPU Crypto: Yes (inactive)

Netgate Services And Support

Retrieving support information

Interfaces

WAN	↑	1000baseT <full-duplex>	192.168.153.136
LAN	↑	1000baseT <full-duplex>	192.168.1.1

➤ Règles de filtrage créées

Action	Interface	Protocole	Port	Description
Pass	LAN	TCP	80 (HTTP)	Autorise uniquement la navigation web non sécurisée

Firewall / Rules / LAN

The changes have been applied successfully. The firewall rules are now reloading in the background. [Monitor the filter reload progress.](#)

Floating WAN LAN

Rules (Drag to Change Order)

☐	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
☒	3 / 255 KiB	*	*	*	LAN Address	443 80	*	*		Anti-Lockout Rule	⚙️
☐	0 / 0 B	IPv4 TCP	*	*	*	*	*	none		Default allow LAN to any rule	⚓ ⚙️ 📄 🗑️
☐	0 / 234 B	IPv4 *	LAN net	*	*	*	*	none		Default allow LAN to any rule	⚓ ⚙️ 📄 🗑️
☐	0 / 0 B	IPv6 *	LAN net	*	*	*	*	none		Default allow LAN IPv6 to any rule	⚓ ⚙️ 📄 🗑️

4. Résultat des Tests Fonctionnement

Après application de la configuration, les tests suivants ont été effectué depuis la machine Ubuntu :

- **Test http (curl <http://example.com>)** : SUCCES. La communication sur le port 80 est autorisée par la règle explicite.

```
morel@morel-virtual-machine:~$ curl http://example.com

Caution: You are using the Snap version of curl.
Due to Snap's sandbox nature, this version has some limitations.
For example, it may not be able to access hidden folders in your home directory
or other restricted areas of the os.

Which means you may encounter errors when using snap curl to download and execute some script.
For those cases, you might want to use the native curl package.
For details, see: https://github.com/boukendesho/curl-snap/issues/1

To stop seeing this message, run the following command:
$ curl.snap-acked

<!doctype html><html lang="en"><head><title>Example Domain</title><meta name="viewport" content="width=device-width, initial-scale=1"><style>body{background:#eee;width:60vw;margin:15vh auto;font-family:system-ui,sans-serif}h1{font-size:1.5em}div{opacity:0.8}a:link,a:visited{color:#348}</style></head><body><div><h1>Example Domain</h1><p>This domain is for use in documentation examples without needing permission. Avoid use in operations.</p><p><a href="https://iana.org/domains/example">Learn more</a></p></div></body></html>
```

- **Test de connectivité ICMP (ping 8.8.8.8)** : ÉCHEC. Aucune règle n'autorisant le protocole ICMP, le trafic est bloqué par défaut.
- **Test de Scan (nmap -sS 8.8.8.8)** : ÉCHEC. pfSense bloque les tentatives de scan sortant, empêchant la reconnaissance réseau.

```
morel@morel-virtual-machine:~$ ping 8.8.8.8
PING 8.8.8.8 (8.8.8.8) 56(84) bytes of data.
From 192.168.131.20 icmp_seq=4 Destination Host Unreachable
From 192.168.131.20 icmp_seq=7 Destination Host Unreachable
From 192.168.131.20 icmp_seq=12 Destination Host Unreachable
From 192.168.131.20 icmp_seq=15 Destination Host Unreachable
From 192.168.131.20 icmp_seq=18 Destination Host Unreachable
From 192.168.131.20 icmp_seq=21 Destination Host Unreachable
^C
--- 8.8.8.8 ping statistics ---
21 packets transmitted, 0 received, +6 errors, 100% packet loss, time 20312ms

morel@morel-virtual-machine:~$ sudo nmap -sS 8.8.8.8
[sudo] Mot de passe de morel :
Starting Nmap 7.80 ( https://nmap.org ) at 2026-04-28 12:17 CEST
Note: Host seems down. If it is really up, but blocking our ping probes, try -Pn
Nmap done: 1 IP address (0 hosts up) scanned in 3.11 seconds
morel@morel-virtual-machine:~$
```

5. Analyse de la Règles

- **Pourquoi la règle fonctionne ?** pfSense applique une politique de "Deny All" par défaut. Seul ce qui est explicitement autorisé passe. Comme nous avons créé une règle "Pass" spécifiant le protocole TCP et le port 80, pfSense inspecte chaque paquet sortant du LAN et ne laisse passer que ceux correspondant à ces critères.
- **Ce qu'elle bloque :**

Elle bloque tous les autres ports (DNS/53, HTTPS/443, SSH/22, etc.) ainsi que les autres protocoles comme ICMP (ping) ou UDP. Cela empêche une machine compromise d'exfiltrer des données via des tunnels non conventionnels ou de scanner le réseau externe.

➤ **Ce qu'elle autorise :**

Exclusivement le trafic web sortant sur le port 80.

6. Proposition d'Amélioration

- **Transition vers HTTPS uniquement :** Modifier la règle pour autoriser le port 443 (TCP) et bloquer le port 80 afin de garantir le chiffrement des communications.
- **Filtrage granulaire :** Bloquer des ports spécifiques souvent utilisés par les malwares pour le Command & Control (C2), comme le port 6667 (IRC) ou des ports de base de données.
- **Mise en place d'une DMZ :** Créer une troisième zone isolée pour les serveurs devant être accessibles depuis l'extérieure, évitant qu'une compromission de ces serveurs ne donne un accès direct au LAN.

Conclusion

Ce TP démontre que la sécurité commence par la maîtrise du réseau. La segmentation et le contrôle des flux via pfSense permettent de limiter drastiquement les capacités d'un attaquant, même si celui-ci parvient à prendre le contrôle d'un poste de travail.